

Warsaw, the 31st
of May
2023

Decision

DKN.5131.8.2021

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended) in connection with Article 7 § 1, Article 60, Article 101, Article 101a § 2, and Article 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as "uodo", as well as Article 57 § 1 letters a) and h), Article 58 § 2 letter i), Article 83 § 1-3, Article 83 § 4 letter a) and Article 83 § 5 letter a) in connection with Article 5 § 1 letter f), Article 5 § 2, Article 24 § 1, Article 25 § 1, Article 32 § 1 and 2, as well as Article 33 § 1 and Article 34 § 1 and 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 4.05.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 4.03.2021, p. 35), hereinafter referred to as "Regulation 2016/679", after conducting administrative proceedings initiated ex officio regarding the violation of personal data protection regulations by P. Sp. z o.o. based in W. at ul. (...), the President of the Personal Data Protection Office, finds that P. Sp. z o.o. based in W. at ul. (...) violated the provisions of Article 5 § 1 letter f), Article 5 § 2, Article 24 § 1, Article 25 § 1, and Article 32 § 1 and 2, as well as Article 33 § 1 and Article 34 § 1 and 2 of Regulation 2016/679, consisting of:

1) failure to implement:

a) appropriate technical and organizational measures to ensure the security of data processing in information systems and the protection of the rights of data subjects,

b) appropriate technical and organizational measures to ensure regular testing, measuring, and assessing the effectiveness of technical and organizational measures intended to ensure the security of personal data processed in information systems, particularly regarding vulnerabilities, errors, and their possible consequences for these systems, as well as actions taken to minimize the risk of their occurrence, which violations result in a breach of the principle of integrity (Article 5 § 1 letter f of Regulation 2016/679) and accountability (Article 5 § 2 of Regulation 2016/679),

2) failure to notify the President of the Personal Data Protection Office of the personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach, and failure to inform without undue delay the data subjects about the personal data breach that poses a high risk to the rights or freedoms of natural persons, imposes on P. Sp. z o.o. based in W. at ul. (...), for the violation of the provisions of Article 5 § 1 letter f), Article 5 § 2, Article 25 § 1, Article 32 § 1 and 2, Article 33 § 1, and Article 34 § 1 and 2 of Regulation 2016/679, an administrative fine in the amount of 47,160 PLN (forty-seven thousand one hundred sixty zlotys).

Justification

On (...) July 2020, the Personal Data Protection Office received information from a third party indicating the loss of concession documentation maintained electronically by P. Sp. z o.o. based in W. (hereinafter also referred to as the "Company" or "Administrator"), which documentation should contain personal data of security employees (employed under an employment contract or individuals performing tasks under civil law contracts), as well as natural persons who are parties to civil law contracts for security services concluded by the Company.

In connection with the above, on (...) July 2020, the President of the Personal Data Protection Office, hereinafter also referred to as the "President of UODO" or "supervisory authority", based on Article 58 § 1 letters a) and e) of Regulation 2016/679, requested the Company to provide information on whether an analysis of the incident had been conducted regarding the risk of violation of the rights or freedoms of natural persons necessary to assess whether there had been a breach of data protection requiring notification of the President of UODO and the individuals affected by the breach. In the letter, the supervisory authority pointed out to the Company the content of Article 33 § 1 and 3 of Regulation

2016/679 and the manner in which it could report the breach. From the explanations provided by the Administrator in response to this and subsequent requests from the supervisory authority (addressed to him before the initiation of administrative proceedings in this matter), it follows, among other things, that:

- 1) As a result of a ransomware attack conducted for the purpose of obtaining financial gain, personal data located on three servers were encrypted, with this data concerning all employees of the Company and individuals providing services to the Company under civil law contracts.
- 2) As a result of the aforementioned incident, the Administrator lost access to the data of the aforementioned individuals belonging to the following categories: surnames, first names, dates of birth, bank account numbers, addresses of residence or stay, PESEL identification numbers, email addresses, salary data, phone numbers, and identity card numbers.
- 3) The Company verified the problem, determined the lack of possibility to decrypt (access to the lost data was not recovered), and accepted that it would be most beneficial to refrain from interference in the system; the Company therefore utilized a paper copy of the data.
- 4) The Administrator, based on the analysis of outgoing data flow, determined that there was no transfer of data outside the company server (the data was not downloaded by an unauthorized person). He also indicated that "(...) it is installed at the interface with access to the Internet and 100% blocks outgoing traffic from within the corporate network. In the process of analyzing (...) logs from network devices and system events, no signs of data exfiltration were observed." No report was prepared from the audit of the IT system conducted by the Company's employees, which (as stated by the Company) showed that there was no unauthorized access to the data processed therein. Furthermore, the Administrator indicated that a backup of the server was created prior to the date of infection (though he did not specify which of the three), while after the incident, professional software was installed - (...) and noted that he conducted periodic analyses of the IT systems.

Importantly, in the context of the Administrator's position regarding the obligations arising from Article 33(1) and Article 34(1) and (2) of Regulation 2016/679, the Company also stated that: 1) "(...) access to the documentation maintained in electronic form, referred to in the aforementioned request, was not lost, but merely blocked [note: which, as indicated in another letter, involves 'losing the ability to open files located on the disk and changing the extension of the said files']. Therefore, it should be considered that there is no risk of infringement of the rights or freedoms of natural persons, and thus, in accordance with Article 33(1) of the General Data Protection Regulation, there is no need to report the breach"; 2) The Administrator conducted an analysis of the impact of the unavailability of the IT system affected by the breach on the rights and freedoms of the individuals concerned. As a result of this analysis, it was determined that it is unlikely that the breach exposed the rights and freedoms of natural persons to risk.

Before the supervisory authority initiated the administrative proceedings in question, there was a situation in which explanations were provided by the wrong company (as explained by the Administrator: due to a clerical error). The Company also sent letters four times that were not signed by persons authorized to represent it. It is worth noting that the Administrator, summoned by a letter dated (...) October 2020 to provide explanations, twice approached the supervisory authority (each time without signing) with a request to extend the deadline for providing information (first with a letter dated: (...) November 2020, and then with a letter dated: (...) November 2020). He then sent explanations in a letter that was received by the local Office on (...) November 2020, which was only marked in the header with a date falling within the deadline that the Company was to meet according to the repeated request for an extension of the deadline, which was received by the local Office on (...) November 2020.

At this stage, from the findings made by the President of the UODO, it was determined that there had been a breach of personal data protection consisting of the breach of the security of the IT system used by the Company to process personal data, and subsequently the encryption of the data processed therein. Consequently, the Company was deprived of access to the aforementioned system and the personal data of all employees of the Company and individuals providing services to the

Company under civil law contracts (i.e., their surnames, first names, dates of birth, bank account numbers, addresses of residence or stay, PESEL identification numbers, email addresses, salary data, phone numbers, and identification card numbers).

In connection with the aforementioned findings, the supervisory authority on (...) January 2021 initiated ex officio administrative proceedings against P. Sp. z o.o. based in W. regarding the failure to report a breach of personal data protection to the President of the UODO, in accordance with Article 33(1) of Regulation 2016/679, and the failure to notify the individuals affected by the breach of personal data protection, in accordance with Article 34(1) and (2) of Regulation 2016/679, as well as regarding the possibility of the Company, as the data controller, breaching the obligations arising from the provisions of Regulation 2016/679, in connection with the breach of personal data protection, in the following scope: Article 5(1)(f), Article 5(2), Article 24(1), Article 25(1), and Article 32(1) and (2) (letter reference: (...)).

After the initiation of the administrative proceedings, the Administrator provided further explanations at the request of the supervisory authority. He provided additional information regarding the incident that occurred, as well as technical and organizational measures to ensure the security of the processed personal data, which information (to avoid repetition of their content and to appropriately systematize them) will be referenced to the appropriate extent in the further part of the justification of this decision.

At this stage, the Company remained consistent and maintained its previously adopted position. It stated, among other things, that "(...) the Company fulfills its obligation under Article 33(5) of Regulation 2016/679 (hereinafter: "Regulation"), however, no breach of personal data has been recorded in the Company's documentation, as - as the Company has repeatedly informed this Authority - the incident in question did not constitute a so-called security incident, and thus a breach of personal data protection within the meaning of Article 4(12) of the Regulation. According to the aforementioned provision, a breach of personal data protection is only situations leading to accidental or unlawful destruction of data, loss/modification of data."

data, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed. Meanwhile, in this case, there was only a blocking of access to data maintained in the IT system. We were therefore dealing with a classic case of so-called "ransomware." Data flow investigations conducted on the day of the incident unequivocally indicated that there was no transfer of data outside the Company's system. Therefore, none of the conditions mentioned in Article 4 point 12 of the Regulation were met, in particular, there was no situation of unauthorized possession of personal data by an unauthorized person.

After the initiation of administrative proceedings in this matter, the Company sent explanations to the supervisory authority two more times, which were not signed by a person authorized to represent it. Furthermore, in the following several months from the date the Company provided its last explanations (in a letter received by this Office on (...) July 2021), the supervisory authority made several attempts to obtain further clarifications from the Company. The questions posed in these letters concerned, among other things, whether the Administrator conducted a risk analysis for the process of processing personal data in electronic form (both before and after the occurrence of the data protection breach), whether the process of restoring personal data processed in electronic form was completed, and whether an audit was conducted, as mentioned in the Company's letter dated (...) March 2021. Unfortunately, the correspondence sent to the Company (addressed to the address disclosed in the National Court Register's Business Register) was not picked up by the addressee.

In this factual state, after reviewing all the evidence gathered in the case, the President of the UODO considered the following:

According to Article 34 paragraphs 1 and 2 of the Personal Data Protection Act, the President of the Office for Personal Data Protection is the competent authority in matters of personal data protection and the supervisory authority within the meaning of Regulation 2016/679. Pursuant to Article 57 paragraph 1 letters a) and h) of Regulation 2016/679, without prejudice to other tasks specified under this regulation, each supervisory authority in its territory monitors and enforces the application of the

aforementioned regulation, as well as conducts proceedings regarding the application of this regulation, including based on information received from another supervisory authority or another public body.

Article 5 of Regulation 2016/679 formulates the principles regarding the processing of personal data that must be respected by all administrators, i.e., entities that independently or jointly with others determine the purposes and means of processing personal data. Article 5 paragraph 2 of Regulation 2016/679 provides that the Administrator is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate compliance ("accountability"). According to Article 5 paragraph 1 letter f) of Regulation 2016/679, personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ("integrity and confidentiality"). The specifics of this principle are further detailed in the provisions of the regulation.

According to Article 24 paragraph 1 of Regulation 2016/679, taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities and severity, the administrator implements appropriate technical and organizational measures to ensure that processing is performed in accordance with this regulation and to be able to demonstrate compliance. These measures are reviewed and updated as necessary.

Pursuant to Article 25 paragraph 1 of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity arising from processing, the administrator - both when determining the means of processing and during the processing itself - implements appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement data protection principles, such as data minimization, and to provide the processing with necessary safeguards to meet the requirements of this regulation and protect the rights of data subjects.

From the content of Article 32 paragraph 1 of Regulation 2016/679, it follows that the administrator is obliged to apply technical and organizational measures corresponding to the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity. The provision specifies that when deciding on technical and organizational measures, one must consider the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity. From the cited provision, it follows that determining appropriate technical and organizational measures is a two-step process.

In the first instance, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria indicated in Article 32 of Regulation 2016/679, and then it is necessary to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk. These determinations, where appropriate, in accordance with letters a), b), c), and d) of this article, should include measures such as pseudonymization and encryption of personal data, the ability to continuously ensure confidentiality, integrity, availability, and resilience.

systems and processing services, the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident, as well as regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of processing. According to Article 32(2) of Regulation 2016/679, when assessing whether the level of security is appropriate, the controller shall take into account, in particular, the risks associated with processing, especially those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data that are transmitted, stored, or otherwise processed.

As indicated in Article 24(1) of Regulation 2016/679, the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons with varying likelihood and severity, are factors that the controller is obliged to consider in the process of building a data protection system, also from the perspective of other obligations specified in Article 25(1), Article 32(1), or Article 32(2) of Regulation 2016/679.

Taking into account the scope of personal data processed by the Company (including first names, last names, dates of birth, bank account numbers, residential or temporary addresses, PESEL identification numbers, email addresses, salary data, phone numbers, personal identification numbers), as well as the categories of individuals whose data are processed (employees of the Company and individuals providing services to the Company under civil law contracts), in order to properly fulfill the obligations imposed by the aforementioned provisions of the regulation, the Company was required to take actions to ensure an adequate level of data protection by implementing appropriate technical and organizational measures, including the use of appropriate technical safeguards, actions aimed at optimal configuration of the operating systems used, and regular measuring and assessing the effectiveness of technical and organizational measures to ensure the security of processing in the form of security tests concerning the IT infrastructure. The nature and type of these actions should result from a conducted risk analysis, in which vulnerabilities related to the utilized resources should be identified, as well as the threats arising from them, and then appropriate security measures should be determined.

Meanwhile, the collected evidence did not contain anything that would indicate that the Company had properly conducted a risk analysis for the process of processing personal data in electronic form (no responses were obtained to the requests for clarification sent to the Company). Failure to assess the level of risk (or incorrect assessment) prevents the application of appropriate security measures for a given resource and increases the likelihood of an infringement (similar effects may arise from a mismatch of security measures to the conclusions drawn from a proper risk analysis).

Regardless of the circumstances related to the risk analysis, it should be stated that the Company did not apply appropriate security measures. The lack of appropriate technical safeguards constitutes a vulnerability, and consequently creates a high threat in the form of reduced system resilience, among other things, to the action of malicious software. As a result, in the analyzed case, the risk materialized: there was a breach of the security of the Company's IT system used by it to process personal data, and subsequently, the data contained in this system were encrypted. The action of the encrypting malware was not stopped by the security mechanisms of the operating systems. The infection occurred on (...) May 2020 (on Saturday), and its scale was verified during periodic checks of the operational correctness of servers and computer workstations conducted by employees.

Not focusing on the lack of information regarding the risk analysis conducted by the Company, in demonstrating the justification for this decision, it is necessary first to systematize the information about what organizational and technical measures were implemented by the Company. Due to the fact that information was not always provided by the Company adequately to the questions asked (which in some cases is significant), in this decision, the Company's explanations will most often be quoted along with the content of the questions to which they were provided. The dates of letters sent by the Company to the local Office will be consistently referred to in the further part of this justification according to the date of their receipt, as the dates indicated in the content of the sent letters are only identical to the dates of their dispatch on two occasions (e.g., in the case of a letter with a receipt date of (...) July 2021, the date indicated in the header is (...) June 2021, and the dispatch date is (...) July 2021).

Thus, in response to the supervisory authority's request dated (...) March 2021 for clarification on who, when, how, and using what tools conducted testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of processed personal data in the IT systems covered by the breach (and what measures these actions concerned), particularly regarding vulnerabilities, errors, and their possible consequences for these systems, as well as actions taken to minimize the risk of their occurrence (while also requesting information on whether as a result of these

actions the Company made any changes to the measures it applied - if so, what and when), the Company measures and actions taken to ensure the security of personal data are insufficient. The lack of a comprehensive security audit, which the Company has repeatedly postponed, raises significant concerns regarding its ability to adequately protect personal data. The assertions made by the Company regarding its preparedness to ensure an appropriate level of security for processed personal data are deemed unfounded, especially in light of the ongoing difficulties in conducting such an audit.

The Company has indicated in its correspondence that it plans to conduct a security audit with the involvement of an external professional entity and to implement all post-audit recommendations. However, the repeated delays and the reasons provided for not conducting the audit, including financial constraints and the potential impact on the Company's operational capabilities, suggest a lack of commitment to addressing the security vulnerabilities that may exist.

In conclusion, the Company's current security measures, while they may include some technical and organizational safeguards, do not appear to be sufficient to mitigate the risks associated with personal data processing. The absence of a timely and thorough security audit further exacerbates these concerns, indicating that the Company may not be in compliance with applicable data protection regulations.

The technical and organizational measures of the Company were not adequate to the existing risk. They should have been selected with consideration of the state of technical knowledge, the cost of implementation, the nature, scope, context, and purpose of processing, as well as the risk of infringement of the rights or freedoms of natural persons. Meanwhile, the circumstances of the occurrence of a breach of personal data protection in the case at hand, as well as the manner in which it was responded to and how its effects were countered, indicate their inadequacy. The Administrator processed personal data of many entities and of a wide scope, which should have been taken into account as a factor indicating the necessity of applying more advanced security measures than those in the present case. Furthermore, the process of their recovery lasted unreasonably long, and the supervisory authority, due to the Company not receiving correspondence, is unable to determine whether it was completed in full.

In summary: due to the lack of application by the Administrator of other security measures than those indicated above aimed at minimizing the risk of infringement of personal data protection, it must be stated that the Company did not implement appropriate technical and organizational measures during the processing of this data, so that the processing took place in accordance with Regulation 2016/679 and in order to provide the necessary safeguards for the processing, which it was obliged to do in accordance with Article 24(1) and Article 25(1) of Regulation 2016/679. This also indicates the Company's failure to fulfill the obligations arising from Article 32(1)(b) of Regulation 2016/679 (it did not apply technical and organizational measures ensuring a degree of security appropriate to the risk associated with the processing of personal data by ensuring the ability to continuously ensure confidentiality, integrity, availability, and resilience of processing systems and services). The Company did not demonstrate that a proper assessment was conducted to determine whether the aforementioned level of security is appropriate, taking into account the risk associated with the processing of personal data (the obligation to conduct such an assessment arises from Article 32(2) of Regulation 2016/679), which is also significant in the context of assessing the Administrator's compliance with the obligation provided for in Article 5(2) of Regulation 2016/679 (the accountability principle).

At this point, it should be emphasized what the Provincial Administrative Court in Warsaw indicated in its judgment of August 26, 2020, case no. II SA/Wa 2826/19: "(...) technical-organizational activities lie within the competence of the personal data administrator, but they cannot be selected in a completely free and voluntary manner, without taking into account the degree of risk and the nature of the protected personal data." The technical and organizational measures indicated by the Administrator proved to be inadequate, which led to a situation where the systems were more susceptible to cyberattacks, including ransomware attacks that block access to data and aim to demand a ransom for

their recovery.

Analyzing the organizational and technical measures implemented by the Company, it is also necessary to refer to the Company's explanations regarding backup copies. From the Company's statements, it follows that the Administrator implemented procedures aimed at ensuring the ability to quickly restore the availability of personal data in the event of a physical or technical incident. Provisions in this regard are included, among others, in paragraph (...) and (...) of the applicable (...) (the content of which was provided to the supervisory authority along with the letter dated (...) July 2021). From these provisions, it follows that: (Paragraph (...) - quote): 1) "In order to ensure the security of personal data processing, the obligation to create backup copies is introduced. The process of creating backup copies is carried out by the Administrator. 2) Access to backup copies is granted only to the Administrator or other persons authorized by them. 3) Backup copies of all personal data sets are created automatically or manually according to subsection 4 below or according to another established schedule. Backup copies may be created using archiving software. 4) Backup copies are created once a week and include copies of all data and applications." (Paragraph (...) - quote): 1. "Backup copies are stored in (...), to which access is granted only to the Administrator or persons authorized by them. Backup copies are not stored in rooms where data sets used during current work are kept. 2. The device for creating backup copies is stored in a locked cabinet in a room that is not a place for current processing of personal data and ensures protection of personal data against unauthorized access, modification, damage, or destruction. 3. Data may be copied to optical, magnetic, or other storage media after being encrypted and stored in locked rooms or cabinets within the area of personal data processing and should not be removed outside this area without justified need. It is permissible to commission the storage of these media to a specialized external entity based on a separate agreement. After the usefulness of these copies ceases, upon the cessation of processing the personal data contained therein, the data must be permanently deleted or the media on which the data is stored must be physically destroyed, so that it is impossible to read the recorded data. 4. During the transport of the media, copies, and prints referred to in subsections 1-3, they are placed in durable packaging and protected against loss, destruction, or damage. Only authorized persons may carry or transport them."

The supervisory authority, requesting further explanations, aimed to determine not only the procedures adopted by the administrator regarding backup copies but also what actions were actually taken. actions taken in this regard by the Company. From the explanations provided by the Company in a letter dated (...) December 2020, it follows that: "Before the date of infection, a backup copy of the server (...) was created," and that: "The Administrator has copies of all data (in paper form)." Furthermore, in a letter dated (...) February 2021, the Company indicated that: "The Company has all the data that was inaccessible due to the actions of malicious software. Additionally, the Company possesses a significant portion of the data in electronic form, which is generated with the assistance of offices - in accordance with point 2," and (in point 2) that: "The state of limited availability of data has been ongoing since (...).05.2020. However, the Company is continuously recovering the aforementioned data by seeking assistance from offices, including the tax office."

Having obtained this information, the supervisory authority requested the Company on (...) April 2021 to provide explanations in the following areas: - how the documentation was maintained by the administrator, the electronic version of which was encrypted due to the actions of malicious software, while requesting clarification, among other things: a) whether the administrator was continuously creating both electronic and paper versions of the produced documentation; and if so, how the compliance of their content was verified, b) whether electronic copies of the electronic version were also created - and if so, how the administrator regularly tested its correctness; - when the administrator created the "backup copy of the server" (mentioned in the Company's letter received by this Office on (...) December 2020), what this copy contained, and whether it could have been used by the administrator to restore the electronic version of the documentation that was inaccessible due to the actions of malicious software.

The Company provided explanations in a letter dated (...) May 2021 - it follows from it that: "The

documentation was maintained as follows: a) a paper version of the documentation was created, and then based on it, an electronic version was created; b) electronic copies of the electronic version of the documents were also created - it was possible to restore the data based on it, but it involved significant expenses that the Company was unable to bear due to the deteriorating financial situation of the Company, which was a result of the restrictions imposed due to the declaration of a state of epidemic threat and subsequently a state of epidemic,” and that: “The copy contained the server's configuration settings. We are unable to determine when it was created. It could not be used to restore the electronic version of the documentation because it was not complete and was also infected.”

Thus, the information gathered by the President of the UODO indicates that the Company did not take actual actions that would ensure the possibility of quickly restoring access to personal data processed in electronic form in the event of a technical incident. This means that the Company acted not only in violation of the provisions, including Article 32(1)(c) of Regulation 2016/679, but also against the procedures referred to in the regulations applicable in the Company (...). Therefore, it is not surprising that (as the Company indicated in its explanations dated (...) November 2020): “Access to the lost data has not been recovered (...).” However, the passivity exhibited by the Company in the face of the violation is concerning - when asked by the supervisory authority on (...) November 2020 about what actions it had taken to recover all data encrypted as a result of the actions of malicious software, the Company responded on (...) December 2020 that: “The Administrator verified the problem, established the lack of possibility to decrypt, and that it would be best to refrain from interfering with the system.”

In summary, it should be stated that prior to the occurrence of the data protection violation in question, the backup creation principles applicable to the Administrator did not ensure compliance with the obligations arising from Article 32(1)(b) and (c) of Regulation 2016/679, i.e., the ability to ensure the ongoing availability of processing systems and services and the ability to quickly restore access to personal data and access to it in the event of a physical or technical incident.

Continuing the considerations regarding security measures, it should be remembered that the role of the administrator is not limited to the one-time development and implementation of organizational and technical measures to ensure the processing of personal data in accordance with the principles expressed in Regulation 2016/679. The necessity for ongoing verification of the adequacy of these measures is particularly important in the case of processing personal data in electronic form. In the event of an incident such as that which occurred in this case (a ransomware attack), it is crucial to analyze the correctness of the Administrator's compliance with its obligation under Article 32(1)(d) of Regulation 2016/679, i.e., regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

The supervisory authority therefore called on the Administrator on (...) November 2020 to provide explanations, among other things, whether, and if so, how it regularly tested, measured, and evaluated the effectiveness of technical and organizational measures to ensure the security of processed personal data in the information systems affected by the breach, particularly regarding vulnerabilities, errors, and their possible consequences for these systems, as well as the actions taken to minimize the risk of their occurrence. The Company in a letter dated (...) December 2020 only indicated that: “The Administrator periodically analyzed the information systems.”

the occurrence of any incidents. The actions taken by the Company, as analyzed above, do not fully satisfy the obligations of the administrator specified in Article 32(1)(d) of Regulation 2016/679. Considering the explanations provided by the Company and the effects of the actions mentioned in those explanations, it must be stated that the technical and organizational security measures concerning the information systems used for processing personal data were not subjected to comprehensive testing. Consequently, the Administrator was unable to demonstrate or confirm that the security measures in place were adequate. The indicated testing, measuring, and evaluation must be conducted regularly to fulfill the requirement arising from Article 32(1)(d) of Regulation 2016/679, which means that such activities must be consciously planned, organized, and documented (in connection with the accountability principle referred to in Article 5(2) of Regulation 2016/679) within specified time intervals, regardless of the occurrence of any incidents.

the Company of its obligations under the regulation. The findings indicate that the technical and organizational measures employed by the Company to ensure the security of personal data were not adequate to the state of technical knowledge, the costs of implementation, and the nature, scope, context, and purposes of processing; these measures, in the opinion of the President of the Personal Data Protection Office (UODO), were not appropriately reviewed and updated, which consequently did not ensure effective implementation of data protection principles.

It should be noted that Regulation 2016/679 introduced an approach in which risk management is the foundation of actions related to the protection of personal data and is characterized as a continuous process. Entities that process personal data are obliged not only to ensure that such processing complies with the guidelines of the aforementioned regulation through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and accountability regarding the level and adequacy of the implemented safeguards. This means that it becomes necessary to demonstrate before the supervisory authority that the solutions introduced to ensure the security of personal data processing are adequate to the level of risk, as well as take into account the nature of the organization and the mechanisms used for processing personal data. The consequence of such an orientation is the abandonment of lists of requirements regarding security imposed by the legislator in favor of independently selecting safeguards based on a threat analysis. Administrators are not provided with specific measures and procedures regarding security. The administrator must independently conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk.

From the analysis of the incident, it follows that the methodology adopted by the Company for internal testing was unable to demonstrate a reliable assessment of the security status of the IT systems indicating all vulnerabilities and resistances to attempts to breach security due to unauthorized actions by third parties and malicious software. Therefore, the assessment of the security status proved insufficient in terms of applying appropriate technical and organizational safeguards.

As previously indicated, the explanations provided by the Company, which concern, among other things, the performance of its obligation under Article 32(1)(d) of Regulation 2016/679, also indicate non-compliance by the Administrator with the principle of accountability referred to in Article 5(2) of Regulation 2016/679. Furthermore, they allow for an appropriate illustration of the course of cooperation between the Administrator and the supervisory authority. An analysis of the content of the letters sent by the Company allows us to conclude that the explanations provided by it are often terse, and moreover, they are sometimes inconsistent or unsupported by the evidence requested by the supervisory authority. The Administrator seems to avoid answering some questions, and the fact that six explanations were sent without the signature of a person authorized to represent the Company (which in five cases were only "confirmed" by the Company at the request of the authority) should also be regarded as a manifestation of inappropriate behavior by the Administrator, as well as the sending of explanations provided on behalf of a completely different company. The evidence collected in this matter, which indicates (at best) a passive attitude of the Administrator towards the incident and the proceedings conducted by the supervisory authority, also justifies a negative assessment of the fulfillment by the Company of its obligations under the regulation.

the obligations set forth in Regulation 2016/679. The inconsistency of some explanations provided by the Administrator is well illustrated by the responses given by him to the supervisory authority's questions regarding whose personal data (and how many individuals) were affected by the breach.

Thus, the Company (to which a request was made on (...) November 2020 to indicate the approximate number of individuals potentially affected by the breach - including individuals who are or were parties to contracts for services provided by the Company) responded in a letter dated (...) December 2020 (quote): "The breach may have involved approximately one thousand individuals." Subsequently, the President of the UODO requested clarification from the Administrator on (...) January 2021 regarding how the Company determined and potentially verified the approximate number of individuals affected by the breach. The Company explained on (...) February 2021 that: "The approximate number of

individuals corresponds to the number of administrative employees (about 30 individuals). At this point, I indicate that in the letter dated (...) 12.2020, due to an obvious clerical error, a different number of individuals was indicated" (emphasis added). Since the information regarding whose personal data was encrypted contradicted the previously provided information in this regard (in the letter dated (...) November 2020), the President of the UODO requested clarification from the Administrator on (...) April 2021 as to whether the encrypted data concerned "all employees of the Company and individuals providing services to the Company under civil law contracts" (as indicated in the Company's letter received by this Office on (...) November 2020), or rather: "administrative employees" (as explained by the Administrator in the letter dated (...) February 2021). The Company clarified in a letter dated (...) May 2021 that: "The attack concerned employees of the Company and individuals providing services to the Company under civil law contracts."

Similarly unsatisfactory appear to be the explanations provided by the Company summoned on (...) November 2020 to provide a copy of the report from the audit conducted by the Company on its information system regarding the possibility of accessing the data processed therein, which the Company mentioned in its explanations dated (...) October 2020. The Administrator provided explanations in this regard on (...) December 2020 - indicating that: "We do not have a copy of the report from the conducted audit due to the fact that it was an audit carried out by the Company's employees and no report was prepared from it" (emphasis added). This response was terse but left hope that the supervisory authority would be able to obtain any additional information from the Company in this regard - even if it came from notes made during conversations conducted by the Administrator with the aforementioned employees. Therefore, on (...) January 2021, the President of the UODO requested the Company to clarify whether the individuals conducting the audit of the information system regarding the possibility of accessing the data processed therein, which the Company mentioned in its explanations dated (...) October 2020, had the qualifications to conduct it and how they presented its results to the Company's management, and additionally, if these results were communicated to the management orally, he requested the Company to provide statements from the individuals preparing the report regarding its content. Unfortunately, the Company provided explanations on (...) February 2021, indicating that: "The results of the audit were communicated orally due to the fact that it was a priority for the Company to restore the possibility of uninterrupted functioning. No detailed report was prepared. The system logs (...) were analyzed manually using the built-in application (...) (...). The entity conducting the findings no longer collaborates with the Company, therefore the Company has no possibility of obtaining statements" (emphasis added).

Unfortunately, as indicated above, receiving inconsistent or terse explanations was not the only difficulty in establishing the factual state in this matter. Obtaining any documents from the Administrator also posed a problem that was difficult to explain from the perspective of this authority, which even concerned the Company's financial documents, for which the President of the UODO requested the Company on (...) January 2021 to present within 30 days of receiving the request, based on Article 101a(1) of the UODO. Based on this provision, the President of the UODO specifically requested the submission within 30 days of receiving the request of the Company's annual financial report for the year 2020 (and in the absence of such, a statement regarding the total annual turnover for the year 2020 and the annual financial report for the year 2019). The Company's lack of response to the President of the UODO's request in this regard forced the supervisory authority to summon the Administrator on (...) April 2021 for explanations regarding why the Company did not present these documents within the deadline specified by the aforementioned law and to again request the submission of the missing documents to this Office. In the same letter, the President of the UODO pointed out to the Company that the failure to provide explanations in this regard may result in the imposition of an administrative monetary penalty in accordance with Article 83(5)(e) of Regulation 2016/679 and informed about the content of Article 108(2) in conjunction with Article 108(1) of the UODO, which states that anyone who, in connection with ongoing proceedings regarding the imposition of an administrative monetary penalty, does not provide data necessary to determine the basis for the assessment of the administrative monetary penalty or provides data that prevent the determination of the basis for the assessment of the administrative monetary penalty, is subject to a

fine, restriction of liberty, or imprisonment for up to two years. After nearly four months had passed since...

****Original summons****

In a letter dated (...) May 2021, the Company indicated that: "The Company has not submitted the annual financial report for 2020 due to the fact that the Company has a shifted financial year which does not coincide with the calendar year. The financial year in the Company ended on (...) March 2021. Consequently, the financial report for the period from (...).04.2020 to (...).03.2021 has not yet been prepared." Along with this letter, the Company also sent the financial report for the period from (...).04.2019 to (...).03.2020, which must have been prepared much earlier.

The failure to submit the aforementioned documents in a timely manner at the request of the President of the UODO should be assessed negatively - especially considering that their non-delivery may be associated with criminal liability. Even if this action was a one-time occurrence. Meanwhile, the repeated action (which has the characteristics of being habitual) and particularly concerning was the submission by the Company to the supervisory authority of letters not signed by persons authorized to represent it. Due to the Company's failure to rectify these deficiencies on its own initiative, the supervisory authority requested the Company to confirm the statements contained in the letters submitted to this Office that were not signed on the following dates: (...) October 2020, (...) November 2020, (...) November 2020, (...) December 2020, as well as (...) March 2021 (the letter dated (...) April 2021 was confirmed by the Company, which was not summoned to do so). It is difficult to consider this as anything other than a sign of the Company's disregard for the supervisory authority. Similarly concerning was the fact that the explanations dated (...) August 2020 were signed by persons representing a completely different company, which was subsequently explained by the Administrator as a "secretariat error."

Indeed, the brevity of the responses provided by the Company has already been demonstrated above, but it is worth illustrating it further by quoting the responses given by the Company to some questions that were posed to the Administrator in an attempt to determine on what basis he refrained from fulfilling the obligations set out in Article 33(1) and Article 34(1) and (2) of Regulation 2016/679.

The President of the UODO summoned the Company on (...) October 2020 for explanations: "Did the administrator conduct an analysis of the impact of the lack of access to the IT systems involved in the breach on the rights and freedoms of the data subjects?" and also: "How did the administrator determine that 'there was no transfer of data outside the company system' - please indicate the actions taken in this regard and the methods of verification of the findings made." The Company, in the explanations provided in a letter dated (...) November 2020, informed that: "The administrator conducted an analysis of the impact of the lack of access to the IT system involved in the breach on the rights and freedoms of the data subjects. As a result of this analysis, it was determined that it is unlikely that the breach exposed the rights and freedoms of natural persons to risk," and also that: "The administrator, based on the examination of outgoing data flows, determined that there was no transfer of data outside the company server. The breach constituted a typical case of so-called 'ransomware' - the data was not downloaded by an unauthorized person, but only encrypted in a manner preventing access to it." The manner of providing the last of the cited responses necessitated a further request for clarification from the supervisory authority on (...) November 2020. The Company, in a letter dated (...) December 2020, provided only the information that: "(...) is installed at the interface with access to the Internet and 100% blocks outgoing traffic from within the corporate network. In the process of analyzing (...) logs from network devices and system events, no traces of data exfiltration were observed." Due to the brevity of the information provided, the supervisory authority, on (...) January 2021, requested the Company to, among other things, provide the results of the analysis of (...) logs from network devices and system events and to provide evidence indicating that there was no loss of confidentiality and integrity of the data. However, the request to provide evidence was never fulfilled by the Company.

As previously indicated, the Company seems to avoid providing explanations requested by the supervisory authority in certain matters. An example of such conduct by the Administrator may be the explanations provided by him in connection with being summoned (in a letter dated (...) November 2020) to indicate whether he conducted an internal investigation that allowed for determining how the

data was encrypted by malicious software; what were the circumstances, source, and causes of the breach (and if so - he was also asked to indicate the findings made in this regard). The Company, in a letter dated (...) December 2020, indicated only that "Details regarding the investigation were disclosed during the proceedings conducted by the Police as a result of a report of a crime. Such information is therefore contained in the case files." In connection with such a formulated response, the supervisory authority again summoned the Company on (...) January 2021 for explanations in this regard (indicating at the same time that the circumstance presented by the Administrator in the letter that was submitted to this Office on (...) December 2020 does not justify the non-provision of this information to the President of the UODO). The Administrator, in a letter dated (...) February 2021, explained that: "Based on the preliminary investigation, it was determined that the Company does not have the tools or means to ascertain the causes and exact circumstances of the incident. Consequently, it was decided to refer the matter to law enforcement authorities." Therefore, the President of the UODO summoned the Company on (...) March 2021 to indicate the results of the proceedings so far.

conducted by law enforcement authorities regarding the subject violation, and after receiving a response on (...)

March 2021, which indicated that the Company had already approached law enforcement authorities for information in this regard and was awaiting a response, additionally requested (on (...) March 2021) to specify the deadline by which the information was to be provided to the Company by these authorities. In response to the last of these requests, the Company only indicated in a letter dated (...) April 2021 that it was awaiting a response from those authorities. No additional information in this regard was provided by the Company to the President of UODO by the date of issuing this decision.

The President of UODO made attempts to clarify the erroneous assumptions made by the Company - an example can be how requests for explanations necessary to determine whether there was a violation of the obligation under Article 33(1) of Regulation 2016/679 were addressed.

As previously mentioned, the supervisory authority contacted the Administrator on (...) July 2020, requesting information on whether, in connection with the situation that occurred, an analysis of the incident had been conducted in terms of the risk of violating the rights or freedoms of natural persons necessary to assess whether there was a data protection breach resulting in the need to notify the President of UODO and the individuals affected by the breach.

In response to the above, on (...) August 2020, a letter was received by this Office in which two members of the board of another company provided the following information: "Acting on behalf of P. S.A., in response to the request for explanations dated (...).07.2020, we hereby inform you that access to the documentation maintained in electronic form, referred to in the aforementioned request, has not been lost, but only blocked. Therefore, it should be considered that there is no risk of violating the rights or freedoms of natural persons, and thus, pursuant to Article 33(1) of the General Data Protection Regulation, there is no need to report a breach" (emphasis added).

In a letter dated (...) September 2020 addressed to the Administrator, the supervisory authority therefore summoned him to explain why the response to the request for explanations directed to P. Sp. z o.o. based in W. was provided by the management of another company. The President of UODO simultaneously signaled to the Company what it should take into account when conducting the aforementioned analysis: noting that in directing another request to the Company, it does not refer to the validity of the explanation presented in the letter dated (...) August 2020, even in the context of the Guidelines of the Article 29 Working Party regarding the reporting of personal data breaches in accordance with Regulation 2016/679 (WP250rev.01), hereinafter referred to as the "Guidelines" [1].

Unfortunately, the Company's representative did not respond to this suggestion and in the response dated (...) September 2020 explained that the letter dated (...) August 2020: "(...) was mistakenly signed by the wrong company due to a clerical error in the company's secretariat, which in turn caused signatures to be affixed by the management of another company," and also stated that: "(...) I fully maintain the position contained in the letter dated (...).08.2020, and it is the position of the company (...) Sp. z o.o.".

The President of UODO, by letter dated (...) September 2020, informed the Company that: "(...) according to Article 4(12) of the General Data Protection Regulation, 'personal data breach' means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed. Blocking access to data is tantamount to losing access to it by the administrator - it is worth noting the Guidelines on reporting personal data breaches in accordance with Regulation 2016/679 (WP250rev.01) (...) of the Article 29 Working Party, which indicate, among other things, that 'As for the concept of "loss" of personal data, it should be interpreted as referring to a situation where data may still exist, but the administrator has lost control over it, no longer has access to it, or is no longer in possession of it.'" In the same letter, the supervisory authority also requested the Administrator to clarify: what constitutes, in the case of the Company, the blocking of access to documentation maintained in electronic form, and additionally again requested information on whether, in connection with the situation that occurred, an analysis of the incident had been conducted in terms of the risk of violating the rights or freedoms of natural persons necessary to assess whether there was a data protection breach resulting in the need to notify the President of UODO and the individuals affected by the breach.

On (...) October 2020, the Company explained that: "(...) in the case of the Company, blocking access to documentation maintained in electronic form consists of losing the ability to open files located on the disk and changing the extension of those files" and that: "(...) the Company conducted an audit of the IT system regarding the possibility of accessing the data processed therein. The audit results indicate that there was no access to the information. They were only encrypted by malicious software on the media on which they were stored - in order to achieve financial gain. There was no transfer of data outside the company system." The same argument was reiterated by the Administrator in letters received by this Office on the following dates: - (...) February 2021, in which he stated that: "The Company reiterates that there was no personal data breach, only blocking access to the data." - (...) July 2021, in which he stated that: "(...) the Company's documentation did not record a personal data breach, as - as the Company has repeatedly stated.

the Company, it is required to notify the supervisory authority without undue delay, and in any case within 72 hours of becoming aware of the breach, unless it is unlikely that the breach will result in a risk to the rights or freedoms of natural persons. The notification must include an explanation of the reasons for any delay if it is submitted after the 72-hour period. The notification must at least: a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of individuals concerned, as well as the categories and approximate number of personal data records concerned; b) provide the name and contact details of the data protection officer or another contact point from which more information can be obtained; c) describe the likely consequences of the personal data breach; d) describe the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

From the content of the aforementioned provisions of Regulation 2016/679, it follows that in the event of a personal data breach on the part of the Company, it is obliged to notify the supervisory authority without undue delay, and in any case within 72 hours of becoming aware of the breach, unless it is unlikely that the breach will result in a risk to the rights or freedoms of natural persons. The notification must include an explanation of the reasons for any delay if it is submitted after the 72-hour period. The notification must at least: a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of individuals concerned, as well as the categories and approximate number of personal data records concerned; b) provide the name and contact details of the data protection officer or another contact point from which more information can be obtained; c) describe the likely consequences of the personal data breach; d) describe the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

obliges the data administrator to report it to the President of the UODO, if the given breach is

associated with a risk of violating the rights or freedoms of individuals - regardless of the level of that risk. In the matter at hand, as clearly indicated by the findings made, there was an encryption of personal data (i.e., loss of availability of data processed in electronic form) on (...) May 2020, affecting approximately thirty individuals: employees of the Company and individuals providing services to it based on civil law contracts, in the form of: surnames, first names, dates of birth, bank account numbers, residential or temporary addresses, PESEL identification numbers, email addresses, salary data, phone numbers, and personal identification numbers. The Company explained that the backup copy of this data created by it cannot be used for recovery (it was not complete, and furthermore, it was also encrypted) and that part of the data in electronic form is being gradually recovered with the help of authorities (which means that the availability of some of the personal data lost as a result of the ransomware attack cannot be restored based on data collected in paper documentation). It should also be emphasized that the Company was pointed to the content of Article 4 point 12 of Regulation 2016/679 and that blocking access to data is equivalent to losing access to it by the administrator. Furthermore, the Administrator was reminded of the content of the Guidelines, which state, among other things, that "When it comes to the concept of 'loss' of personal data, it should be interpreted as referring to a situation where data may still exist, but the administrator has lost control over it, no longer has access to it, or is no longer in possession of it." In the analyzed case, there was a breach of security leading at least to the loss of availability of the data of these individuals, which determines that there was a violation of personal data protection. "At least" - in light of the lack of evidence - there is no certainty that there was also a loss of confidentiality of that data. It is also worth pointing out the Guidelines of the European Data Protection Board 01/2021 on examples of reporting personal data breaches adopted on December 14, 2021, version 2.0, in which it was noted, among other things, that "The Administrator must remember that if the attack is more advanced, the malware may edit log files and erase traces. Therefore - considering that logs are not transmitted or replicated to a central log server - even after conducting a thorough investigation, during which it was shown that personal data was not exfiltrated by the perpetrator of the attack, the data administrator cannot state that the absence of an entry in the log proves the absence of exfiltration, and thus the probability of a breach concerning confidentiality cannot be completely dismissed."

The breach of personal data protection that occurred in this case, contrary to the claims of the Company contained in the correspondence addressed to the President of the UODO, results in a risk of violation of the rights or freedoms of individuals. As indicated by the Article 29 Working Party in the Guidelines: "When assessing the risk to individuals resulting from a breach, the administrator should take into account the specific circumstances of the breach, including the severity of the potential impact and the likelihood of its occurrence." The Article 29 Working Party therefore recommends that during the assessment, the following criteria be taken into account, among others: the type of breach, the nature, sensitivity, and amount of personal data, the ease of identifying individuals, the severity of consequences for individuals, the specific characteristics of the individual and the data administrator, as well as the number of individuals affected by the breach. The administrator conducts business in the field of protection of persons and property and is thus obliged under Article 19 paragraph 1 point 2 letter a) of the Act of August 22, 1997 on the protection of persons and property (Journal of Laws of 2021, item 1995) to maintain and store documentation concerning security personnel, including employment contracts and civil law contracts, with the requirement that according to § 5 point 1 - 3 of the Regulation of the Minister of the Interior of December 16, 2013, on documenting business activities in the field of personal and property protection services (Journal of Laws of 2013, item 1739), this documentation is maintained with regard to the necessity of: securing against damage, loss, or unauthorized alteration of data, maintaining integrity and reliability, and the possibility of verification based on source documents stored at the entrepreneur's premises or at the place of business, as well as ensuring access to documentation for authorized persons and securing against access by unauthorized persons.

In this case, it should not go unnoticed that the breach of personal data protection concerned - in addition to names and surnames - also, among others, PESEL identification numbers and salary data. As indicated in the Guidelines: "A key factor when assessing risk is, of course, the type and sensitivity

of the personal data that has been disclosed as a result of the breach. Typically, the risk of harm to individuals affected by the breach increases with the sensitivity of the data (...)." In the situation that has arisen, it should also not be forgotten that the administrator's loss of access to data also means the loss of access to the data of the individual whose data has been encrypted, which violates their "right of access" referred to in Article 15 of Regulation 2016/679.

Considering the entirety of the findings made in the case, as well as the inability to verify based on the technical measures indicated by the Company, whether unauthorized persons gained access to the data affected by the breach, it should be concluded that in this case there is a risk of violation of the rights or freedoms of individuals affected by the breach.

****Consequences of Data Breach Notification Obligations****

This results in the Company, as the administrator of such data, being obligated to report the personal data breach to the supervisory authority, in accordance with Article 33(1) of Regulation 2016/679, which must include the information specified in Article 33(3) of Regulation 2016/679. It is worth emphasizing that the Guidelines indicate that: "(...) when assessing the risk that may arise from a breach, the administrator should take into account the severity of the potential impact on the rights and freedoms of natural persons and the likelihood of its occurrence. Of course, the risk increases when the consequences of the breach are more serious, as well as when the likelihood of their occurrence increases. In case of any doubts, the administrator should report the breach, even if such caution may seem excessive."

It is particularly important to note that the possible consequences of the incident do not have to materialize - the content of Article 33(1) of Regulation 2016/679 states that the mere occurrence of a personal data breach, which is associated with a risk to the rights or freedoms of natural persons, implies the obligation to report the breach to the appropriate supervisory authority. The correctness of this approach has been confirmed multiple times in the justifications issued by the Provincial Administrative Court in Warsaw (see: judgment of September 22, 2021, in case no. II SA/Wa 791/21, judgment of July 1, 2022, in case no. II SA/Wa 4143/21, or judgment of January 21, 2022, in case no. II SA/Wa 1353/21).

It should also be emphasized that the Company, when processing personal data in electronic form, should be aware of the risks associated, for example, with ransomware attacks. The existence of these risks, in the absence of actions by the data administrator aimed at minimizing them through the implementation of appropriate organizational and technical measures, directly leads to the emergence of a risk of violation of the rights or freedoms of natural persons whose data is processed in this manner. Therefore, in this case, it is also concerning that the Company, despite the occurrence of a personal data breach, did not implement changes in the actions taken to ensure the security of personal data indicated in the explanations dated (...) April 2021. This is evidenced by the fact that the same measures were referenced by the Administrator in response to a question posed in a letter sent to the Company on (...) June 2021, in which the supervisory authority called upon the Administrator to provide explanations regarding the security measures implemented to minimize the risk of a recurrence of the breach. Furthermore, the Company explained in the same letter that no changes were made to the applicable measures at the Administrator's (...) and (...). Changes were only indicated in the explanations submitted to this Office on (...) December 2020, which state that: "(...) after the incident, professional software was installed - (...)".

In a situation where, as a result of a personal data breach, there is a risk of violation of the rights or freedoms of natural persons, the administrator is obliged to implement all appropriate technical and organizational measures to immediately identify the personal data breach and promptly inform the supervisory authority. The administrator should fulfill this obligation as quickly as possible. Recital 85 of the preamble to Regulation 2016/679 explains: "In the absence of an appropriate and timely response, a personal data breach may result in physical harm, material or non-material damage to natural persons, such as loss of control over their personal data or restriction of rights, discrimination, identity theft or fraud, financial loss, unauthorized reversal of pseudonymization, damage to reputation, breach of confidentiality of personal data protected by professional secrecy, or any other significant

economic or social damage. Therefore, immediately after identifying a personal data breach, the administrator should report it to the supervisory authority without undue delay, if feasible, no later than 72 hours after the breach is identified, unless the administrator can demonstrate in accordance with the accountability principle that it is unlikely that the breach could result in a risk to the rights or freedoms of natural persons. If it is not possible to report within 72 hours, the report should be accompanied by an explanation of the reasons for the delay, and information may be provided gradually, without further undue delay.”

Consequently, it should be stated that the Company did not report the personal data breach to the supervisory authority within the time frame specified in Article 33(1) of Regulation 2016/679, which constitutes a violation of this provision by the Company.

According to Article 34(1) and (2) of Regulation 2016/679, in a situation where, as a result of a personal data breach, there is a high risk of violation of the rights or freedoms of natural persons, the administrator is obliged to notify the affected individuals of such a breach without undue delay. The notification should describe the nature of the personal data breach in clear and plain language (e.g., presenting the circumstances of the breach along with a description of the categories of data that were breached) and include at least the information and measures referred to in Article 33(3)(b), (c), and (d) of Regulation 2016/679.

The administrator notifies individuals about the breach of their data individually, unless this would require a disproportionate effort. In such a case, the administrator issues a public communication or uses a similar measure to inform the affected individuals in an equally effective manner (Article 34(3)(c) of Regulation 2016/679).

As previously indicated, the Administrator assumed that as a result of the ransomware attack, there was no breach of personal data protection. Based on this - erroneous in the assessment of the supervisory authority - assumption, it was not evaluated whether there was a high risk of infringement of the rights or freedoms of natural persons, which would require notifying the individuals concerned about the breach of their personal data protection.

The fact that part of the encrypted data was subsequently recovered with the help of authorities indicates a loss of availability for at least several months. Seeking assistance from authorities to recover lost data casts doubt on the truthfulness of the Company's explanations regarding the possession of all lost data in paper form.

In the explanations provided by the Company, it is also difficult to find justification for the assertion that the incident did not result in a breach of the confidentiality of personal data (including, among others, names, surnames, and PESEL identification numbers) contained in the systems subject to the ransomware attack. Considering the above, as well as the scope of the breached personal data and the duration of their unavailability due to the encryption of backup copies and the lack of the possibility of quickly restoring the encrypted data, it must be concluded that there was a high risk of infringement of the rights or freedoms of natural persons.

Consequently, the Company was obliged to notify the individuals concerned about the breach of their personal data protection, in accordance with Article 34(1) of Regulation 2016/679, providing them with the information specified in Article 34(2) of Regulation 2016/679.

In light of the above, it should be concluded that the Administrator incorrectly stated that there was no breach of personal data protection, and consequently did not recognize that this incident was associated with a high risk of infringement of the rights or freedoms of natural persons (hence there was no notification of the breach to the individuals concerned). Therefore, it should be concluded that the administrator violated Articles 34(1) and 34(2) of Regulation 2016/679.

In connection with the above findings made in the case, it should be stated not only that the Company (by not applying technical and organizational measures ensuring the security of processed data, resulting in a breach of personal data protection) violated Article 5(1)(f) of Regulation 2016/679, reflected in the form of obligations specified in Articles 24(1), 25(1), 32(1), and 32(2) of Regulation

2016/679, but also failed to fulfill the obligations arising from Article 5(2) of this Regulation.

The fact of the Administrator's violation of the accountability principle is also evidenced by its terse and inconsistent explanations and the consistent failure to provide evidence of their truthfulness. The above is confirmed by the ruling of the Administrative Court in Warsaw dated February 10, 2021, case reference II SA/Wa 2378/20: "The principle of accountability is therefore based on the legal responsibility of the administrator for properly fulfilling obligations and imposes on them the obligation to demonstrate, both to the supervisory authority and to the data subject, evidence of compliance with all data processing principles." Similarly, the issue of the accountability principle is interpreted in the ruling dated August 26, 2020, by the Administrative Court in Warsaw, case reference II SA/Wa 2826/19: "Considering the entirety of the norms of Regulation 2016/679, it should be emphasized that the administrator has considerable freedom regarding the security measures applied; however, they are also responsible for violations of data protection regulations. The principle of accountability directly implies that it is the data administrator who should demonstrate, and thus prove, that they comply with the provisions specified in Article 5(1) of Regulation 2016/679."

Furthermore, it should be concluded that there were no justified grounds for the Company to assume the lack of necessity to fulfill the obligations arising from Articles 33(1) and 34(1) and (2) of Regulation 2016/679.

In light of the above findings, the President of the Personal Data Protection Office, exercising the authority granted to them under Article 58(2)(i) of Regulation 2016/679, according to which each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a)-(h) and (j) of this Regulation, an administrative fine under Article 83(4)(a) and (5)(a) of Regulation 2016/679, taking into account the circumstances established in the proceedings, stated that there were grounds justifying the imposition of an administrative fine on the Administrator.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the administrator and the processor, referred to in Articles 8, 11, 25-39, and 42 and 43, are subject to an administrative fine of up to EUR 10,000,000, and in the case of an enterprise - up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

According to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the fundamental principles of processing, including the conditions for consent, referred to in Articles 5, 6, 7, and 9, are subject to an administrative fine of up to EUR 20,000,000, and in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

Article 83(3) of Regulation 2016/679 states that if the administrator or processor intentionally or unintentionally violates within the same or related operations... processing several provisions of this regulation, the total amount of the administrative monetary penalty does not exceed the amount of the penalty for the most serious violation.

In this case, the administrative monetary penalty imposed on the Company was for violating Article 25(1), Article 32(1) and (2), Article 33(1), and Article 34(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679 - based on Article 83(5)(a) of that regulation. At the same time, the penalty amounting to the equivalent of EUR 10,000 imposed on the Company for the violation of all the above provisions - in accordance with Article 83(3) of Regulation 2016/679 - does not exceed the amount of the penalty for the most serious violation identified in this case, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which, according to Article 83(5)(a) of Regulation 2016/679, is subject to an administrative monetary penalty of up to EUR 20,000,000, or in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year.

In deciding to impose an administrative monetary penalty on the Company, the President of the UODO - in accordance with the provisions of Article 83(2)(a-k) of Regulation 2016/679 - took into account the following circumstances of the case, which are aggravating and have an impact on the amount of the imposed financial penalty:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). In determining the penalty, it was significant that the violation of the provisions of Regulation 2016/679, which impose obligations on the controller regarding the application of appropriate technical and organizational measures to ensure the security of the processed personal data, primarily affected the availability of data of a special category of data subjects. This violation indirectly harms the interests of employees whose data the Company should protect, and may also be associated with negative consequences in light of the provisions of other areas of law (labor law, social security, or accounting regulations). Considering the aspect of the purpose of processing, it should be noted that the processing of employees' personal data requires particular diligence, and there is an imbalance between the Company (employer or principal) and the data subjects (employees or contractors). The violation of the aforementioned provisions identified in this case is of significant weight and serious nature also because it may lead to material or non-material damages for the individual whose data has been violated, and the probability of their occurrence cannot be excluded. Furthermore, the risk arising from the broad scope of data covered by the violation should be taken into account. It should be emphasized that it is unknown whether, apart from the violation of data availability (even if temporary, but causing the individuals concerned to potentially suffer material damage), there was also a breach of the confidentiality of that data, which also constitutes non-material damage (harm). The data subject may at least feel fear of losing control over their personal data, identity theft, or identity fraud, or finally, financial loss. It is also significant in this context that the individuals whose data were subject to the violation were not properly informed about it (i.e., about its circumstances, consequences, or risks associated with it), and therefore cannot counteract potential damages. It should be assumed that the violation of the provisions of Article 5(1)(f), Article 5(2), Article 25(1), and Article 32(1) and (2) began even before the occurrence of the personal data breach (i.e., before the day of (...) May 2020). Meanwhile, the violation of the obligations arising from Article 33(1) and Article 34(1) and (2) of Regulation 2016/679 has been ongoing since the moment the Controller was required to fulfill its informational obligations arising from these provisions. Considering this premise, it should also be noted that the personal data breach concerned data of approximately 30 individuals.

2. The intentional or unintentional nature of the violation (Article 83(2)(b) of Regulation 2016/679). According to the Guidelines of the Article 29 Working Party on the application and determination of administrative monetary penalties for the purposes of Regulation No. 2016/679 WP253 (adopted on October 3, 2017, approved by EROD on May 25, 2018), intent "includes both knowledge and deliberate action, in relation to the characteristics of the prohibited act." The Company made a conscious decision, among other things, not to notify the President of the UODO about the violation, as well as the individuals whose data were concerned. There is no doubt that the Company, processing personal data of individuals working or contracting for it, must have knowledge regarding personal data protection, including knowledge of the consequences of identifying a personal data breach resulting in a high risk of violating the rights or freedoms of natural persons. Being aware of this, the Controller nevertheless made a decision, among other things, to refrain from reporting the breach to the President of the UODO and notifying the individuals whose data were concerned, despite the fact that the President of the UODO had initially informed the Company about the obligations imposed on the controller in connection with the data protection breach. Ultimately, the very initiation by the President of the UODO of this proceeding regarding, among other things, the obligation to report the personal data breach to the supervisory authority and to notify the individuals whose data... relating to, should at least raise doubts for the Administrator regarding the correctness of the position he has adopted. However, the supervisory authority did not find that the violation of other provisions (i.e., in particular, Article 25(1) and Article 32(1) and (2) of Regulation 2016/679) had a deliberate

character in this case—it rather resulted from negligence on the part of the Company, which does not change the fact that the criterion from Article 83(2)(b) of Regulation 2016/679 should be considered in this case as generally aggravating.

3. The degree of cooperation with the supervisory authority in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The evidence gathered in this case does not indicate anything that would demonstrate the actual involvement of the Company in remedial actions aimed at eliminating the violation and mitigating its potential negative effects, apart from declared attempts to recover data availability with the help of the relevant authorities (and it is unclear whether these actions were fully effective). During the proceedings (within the framework of cooperation with the authority), the Company did not undertake practically any actions aimed at implementing appropriate technical and organizational safeguards, new procedures for regular testing and examination of already implemented measures, etc. The aforementioned evidence also does not indicate that the Administrator conducted an analysis of the impact of the personal data breach on the rights or freedoms of the affected individuals, nor did he perform an audit, which he declared to conduct after the breach. Meanwhile, attempts to recover data availability with the help of the relevant authorities are merely an attempt to fulfill the "ordinary" obligation resting on the Administrator.

4. Categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679). The personal data to which the Company lost (even temporarily) access (and to which unknown and unauthorized third parties could potentially gain access) do not belong to the special categories of personal data referred to in Article 9 of Regulation 2016/679. However, their broad scope (i.e., names, surnames, dates of birth, bank account numbers, residential or temporary addresses, PESEL identification numbers, email addresses, salary data, phone numbers, identity card numbers) is associated with a high risk of violation of the rights or freedoms of the individuals affected by the breach. It should be emphasized that in particular, the fact that the breach involved the PESEL identification number (in conjunction with the name and surname) can realistically and negatively affect the protection of the rights or freedoms of individuals. The PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies an individual, containing among other things the date of birth and gender designation, and thus closely linked to the private sphere of the individual and also subject, as a national identification number, to special protection under Article 87 of Regulation 2016/679, is data of a special nature and requires such special protection.

5. The manner in which the supervisory authority became aware of the breach (Article 83(2)(h) of Regulation 2016/679). The President of the UODO learned about the breach of personal data protection regulations that are the subject of these proceedings from a third party. In this case, it is particularly important to emphasize that the supervisory authority was not informed about the occurrence of the personal data breach in accordance with the procedure provided for such situations as specified in Article 33 of Regulation 2016/679.

6. Other aggravating or mitigating factors (Article 83(2)(k) of Regulation 2016/679). In considering this criterion, the President of the UODO deemed it appropriate to take into account that the Company did not provide comprehensive explanations in response to the supervisory authority's requests—responses to the questions posed were often terse or inconsistent. The timeliness and manner of their provision (e.g., repeatedly sending documents not signed by persons authorized to represent the Company) are detrimental to the Administrator when assessing his cooperation with the President of the UODO.

In determining the amount of the administrative monetary penalty, the President of the UODO found no grounds to consider mitigating circumstances that would affect the final amount of the penalty. All the criteria listed in Article 83(2)(a) - (j) of Regulation 2016/679, in the opinion of the supervisory authority, constitute either aggravating criteria or are merely neutral. Also, applying the criterion mentioned in Article 83(2)(k) of Regulation 2016/679 (which requires consideration of all other aggravating or mitigating factors applicable to the circumstances of the case), no mitigating circumstances were found, only neutral ones (as noted below in point 6 regarding financial benefits gained directly or indirectly in connection with the breach or avoided losses) and aggravating ones (indicated in point 6

above).

The fact that the President of the UODO applied a sanction in the form of an administrative monetary penalty against the Company in this case, as well as its amount, was not influenced by other circumstances indicated in Article 83(2) of Regulation 2016/679, namely:

1. Actions taken to minimize the damage suffered by the individuals whose data are concerned (Article 83(2)(c) of Regulation 2016/679). In this decision, it was indicated as an aggravating circumstance that the individuals whose data are concerned may continue to suffer property damage, and the occurrence of the data breach may lead to non-material damage (harm). In the gathered...

****1.**** There is no evidence material indicating the occurrence of material damages. Considering this premise, it should be noted in passing that the Company did not take appropriate actions to minimize the non-material damages suffered by the individuals to whom this data pertains.

****2.**** The degree of responsibility of the administrator, taking into account the implemented technical and organizational measures (Article 83(2)(d) of Regulation 2016/679). The Guidelines adopted on October 3, 2017, by the Article 29 Working Party regarding the application and determination of administrative fines for the purposes of Regulation No. 2016/679 indicate that when considering this premise, "the supervisory authority must answer the question of to what extent the administrator 'did everything that could be expected,' considering the nature, purposes, or scope of processing and in light of the obligations imposed on them by the regulation." The President of the UODO stated in this case that the Company violated the provisions of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679. In his opinion, the administrator bears a high degree of responsibility for the failure to implement appropriate technical and organizational measures that would have prevented the violation of personal data protection. It is evident that in the context of the nature, purpose, and scope of personal data processing, the Administrator did not "do everything that could be expected of them"; thus, they failed to fulfill the obligations imposed on them by Articles 25 and 32 of Regulation 2016/679. In this case, this circumstance constitutes the essence of the violation itself; it is not merely a factor influencing - mitigating or aggravating - its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Articles 25 and 32 of Regulation 2016/679 cannot be recognized by the President of the UODO in this case as a circumstance that could additionally influence a stricter assessment of the violation and the imposition of an administrative fine on the Administrator.

****3.**** Relevant previous violations of the provisions of Regulation 2016/679 (Article 83(2)(e) of Regulation 2016/679). The President of the UODO did not find relevant previous violations of Regulation 2016/679 by the Company; therefore, there are no grounds to treat this circumstance as aggravating. However, it is the duty of every administrator to comply with the law (including provisions concerning the protection of personal data), which means that the lack of previous violations of the aforementioned legal act cannot be considered a mitigating circumstance when imposing sanctions.

****4.**** Compliance with previously applied measures in the same case, referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of the UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679 against the Company in the case under consideration, which means that the Administrator had no obligation to take any actions related to their implementation, and such actions, assessed by the President of the UODO, could have had an aggravating or mitigating impact on the assessment of the established violation.

****5.**** The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Company does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for administrators and processors, as stipulated by the provisions of Regulation 2016/679; therefore, the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and

applying such instruments as measures guaranteeing a higher than standard level of protection for processed personal data could be taken into account in favor of the Administrator.

****6.**** Financial benefits obtained directly or indirectly in connection with the violation or losses avoided (Article 83(2)(k) of Regulation 2016/679). The President of the UODO did not find that the Administrator obtained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds to treat this circumstance as aggravating for the Administrator. The existence of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 would need to be assessed very negatively. Conversely, the Administrator's failure to achieve such benefits, as a natural state independent of the violation and its consequences, is a circumstance that, by its very nature, cannot be mitigating for the Administrator. This is confirmed by the wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "obtained" - that is, those that occurred on the part of the entity committing the violation. The President of the UODO, comprehensively considering the case, did not note any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative fine, which should be taken into account in the context of the premise from Article 83(2)(k) of Regulation 2016/679.

In the opinion of the President of the UODO, the applied administrative fine fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case.

It should be emphasized that the penalty will be effective if its imposition leads to the Company, which is obliged to process personal data in accordance with the requirements not only arising from Regulation 2016/679 but also other provisions (mentioned in this justification), fulfilling its obligations regarding data protection in the future, particularly in terms of reporting personal data breaches to the President of the UODO and notifying the individuals affected by the breach.

In the opinion of the President of the Personal Data Protection Office, the administrative fine will serve a repressive function, as it will constitute a response to the Company's violation of the provisions of Regulation 2016/679. It will also serve a preventive function; in the opinion of the President of the UODO, it will indicate to both the Company and other data controllers the reprehensibility of neglecting the obligations of controllers related to the occurrence of personal data breaches, which aim to prevent their negative and often severe consequences for the individuals affected by the breach, as well as to eliminate these consequences or at least mitigate them.

Pursuant to the provisions of Article 103 of the UODO, the equivalent amounts expressed in euros, referred to in Article 83 of Regulation 2016/679, are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year - according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

In the opinion of the President of the UODO, the imposed monetary penalty of 47,160 PLN (forty-seven thousand one hundred sixty zlotys), which is equivalent to 10,000 euros (average euro exchange rate from January 30, 2023 - 4.7160 PLN), meets the conditions referred to in Article 83(1) of Regulation 2016/679 due to the severity of the established violation in the context of the fundamental objective of Regulation 2016/679 - the protection of the fundamental rights and freedoms of natural persons, particularly the right to the protection of personal data.

The collected evidence does not contain data regarding the total annual global turnover of the Company from the previous financial year. However, the Company provided information regarding its net sales revenue and equivalent for the period from (...) April 2019 to (...) March 2020 (which amounted to 6,948,467.84 PLN) and for the preceding financial year (8,827,593.26 PLN). These data indicate relatively high turnover during the examined period and the fact of its decrease - they could, among other things, serve to estimate the basis for determining the amount of the administrative monetary penalty in accordance with the provisions of Article 101a(2) of Regulation 2016/679.

Referring to the amount of the administrative monetary penalty imposed on the Company, the President of the UODO considered that it is proportional to the violations that occurred - it is worth emphasizing that the amount of the imposed penalty of 47,160 PLN is only: - 0.1% of the maximum penalty that the President of the UODO could impose on the Company for the violations established in this case - applying the static maximum penalty in accordance with Article 83(4) of Regulation 2016/679 (i.e. 10,000,000 euros) - 0.05% of the maximum penalty that the President of the UODO could impose on the Company - applying the static maximum penalty in accordance with Article 83(5) of Regulation 2016/679 (i.e. 20,000,000 euros).

In this factual and legal state, the President of the Personal Data Protection Office ruled as in the operative part.

[1] It should be noted that the principles set out in these Guidelines have been clarified and developed in the Guidelines of the European Data Protection Board 9/2022 on reporting personal data breaches in accordance with the GDPR (version 2.0) adopted on March 28, 2023.

Print article

Metadata

Entity providing the information:

Department of Control and Violations

Information created by:

Jan Nowak

2023-05-31

Information introduced by:

Wioletta Golańska

2023-07-11 13:35:06

Last modified by:

Edyta Madziar

2023-07-19 12:22:42